Stakeholder Communication Portfolio

Table of Contents

Internal notifications 2
Executive briefings and recommendations 3
Regulatory notifications 5
Member notification letter 9
Employee communications 11

1. **Internal notifications**

CISO

URGENT: Suspected Ransomware Incident

Time: 6:45 AM, Dec 1

Status: Critical security incident confirmed

Action Required: Immediate escalation to the CEO and executive team

Details: Activated CSIRT. Immediate containment initiated. File servers are infected and isolated. The threat actor claims data exfiltration and encrypted backups. Ransom demand received. Recommend convening the Executive Crisis Team ASAP. Will provide a formal update in 30 minutes.

CEO

EXECUTIVE ALERT: Critical Cybersecurity Incident

We have confirmed ransomware affecting multiple systems. Member data may be compromised. CSIRT activated. An emergency leadership meeting is required at 8:00 AM. No immediate member notification is required. Further details will be provided by the CISO/COO once we confirm the scope and impact.

CSIRT members

ALL HANDS: Critical Ransomware Incident - CSIRT Activation

Meeting: Emergency conference bridge 4. Join the IR War Room NOW

Priority: Critical - Containment and assessment

Don’ts: Do NOT use email for IR communication.

Do NOT log into infected servers.

Do NOT power off systems without instruction.

First priority: Containment and Forensic Acquisition. Roles will be assigned on the call.

2. Executive briefings and recommendations

Board Briefing: Critical Incident Recovery Decision

To: The Board of Directors

From: Incident Response Manager

Date: Tuesday,2nd December 2025 6:00 AM (Hour 24)

Subject: Recovery Decision Point: Recommendation for Complete Network Rebuild

Current Situation Summary

- **Status:**

  The attack has been contained, as there has been no further encryption since 6:45 AM Monday. Affected systems remain offline and isolated.

- **Compromise:**

  Confirmed double extortion attack (REvil/Sodinokibi) via a TrickBot infection 3 weeks ago. Domain Administrator credentials were stolen.

- **Data Breach:**

  Confirmed mass data exfiltration of 340 GB, including full member PII/NPI (SSNs, accounts). This triggers immediate GLBA and state notification requirements.

- **Business Impact:**

  Core banking is functional, but loan processing and customer service are severely limited. Three large commercial members are threatening withdrawal within 7 days.

Recovery Options & Analysis

Option	Pros	Cons	Cost $
A: Pay Ransom	Fastest recovery (24-48 hours).	• There is no guarantee of data deletion. • Ransom funds criminal activities. Risk of OFAC sanctions. • It does not reduce exfiltration impact.	2,100,000
B: Old Backups	Offers the lowest cost to recovery	• Unacceptable 45 days of data loss. • Massive manual reconciliation cost and time.	650,000

		• High risk of restoring malware.	
C: Full Rebuild	• Guarantees eradication and long-term security. • Opportunity to deploy a modern, hardened environment.	• Longest recovery timeline (14-21 days). • The highest revenue loss cost.	700,000
D: Hybrid (Pay & Rebuild)	Fast initial restoration.	• Highest total direct cost. • Still funds criminals. • Risk of migrating malware from the decrypted systems.	2,500,000

Recommendation and Rationale

Recommendation: Option C - Complete Network Rebuild.

Rationale:

1. The compromise of Domain Administrator credentials means the only safe and responsible path is a complete rebuild of the core infrastructure. Any solution that reuses the infected environment (A, B, or D) carries an unacceptable risk of immediate reinfection.
2. Regulatory Compliance: The data exfiltration makes breach notification inevitable. Paying the ransom (A/D) is illegal under some circumstances, funds criminal enterprises, and does not satisfy our legal duty to notify members. Option C upholds our legal and ethical duty to secure the environment.
3. Long-Term Resilience: While the 21-day timeline is challenging, it transitions the organization to a secure, hardened, and auditable environment, preventing recurring incidents that would ultimately cost far more in the long run.

3. **Regulatory Notifications**

NCUA NOTIFICATION

To: NCUA

Subject: Finance First Credit Union Notification of Confirmed Data Breach.

Field	**Detail**
Credit Union Name	FinanceFirst Credit Union
Charter Number	4567809432
Reporter Name/Title	Incident Response Manager
Callback Number/Email	+4532678
Date/Time Incident Detected	Monday 1st December 2025, 6:25 AM EST

Incident Description and Timeline

Date/Time	**Event**
Nov 10, 3:42 PM	Initial compromise via phishing email to HR employee
Nov 10, 4:15 PM	Malicious macro executed, TrickBot malware installed
Nov 11-17	Lateral movement, credential harvesting, network reconnaissance
Nov 18	Domain administrator credentials compromised
Nov 19-Dec 1	Data exfiltration (estimated 340 GB transferred to external server)
Dec 1, 4:25 AM	Backup server encrypted
Dec 1, 6:25 AM	Mass encryption of production systems initiated

Affected Systems and Data

Confirmed affected systems include:

- 8 file servers (Windows Server 2019)
- Primary database server (member account database)
- Email server (Microsoft Exchange)
- Backup server (Veeam backup repository)
- 45 workstations across the headquarters and 3 branch locations

Preliminary forensic findings indicate approximately 340 GB of data exfiltrated, including:

- Member database (full copy including SSNs, account numbers, balances, transaction history)
- Employee records (SSNs, salary information, performance reviews)
- Email archives (executive communications, board meeting minutes)
- Loan application documents (financial statements, tax returns, credit reports)

Response Action Taken.

- Activated CSIRT and isolated all affected systems
- Engaged third-party forensic investigation firm
- Notified cyber insurance carrier
- Preserved evidence and initiated legal counsel coordination
- Began containment, eradication, and recovery procedures
- Recommended full network rebuild to ensure complete eradication.

Estimated Impact and Recovery Timeline

The estimated impact of the security incident is **high** for the foregoing reasons:

- An estimated 85,000 members potentially impacted.
- Data exfiltration confirmed of financial and PII exposure.
- Internal administrative functionality currently impaired
- Branch operations continue at reduced capacity

Recovery Timeline:

- Containment: **1-24 Hours**
- Eradication (New IAM/Infrastructure Build): **7 days**
- Core Banking System Restore & Validate **10 days**
- Member Services & Critical Systems Restore **15 days**
- Full Operational Recovery **21 days**

Compliance with notification timeline requirements

This notification is being provided within the required 72-hour timeframe as discovery was made on 1st December 2025 at 6.25 am. We will provide additional updates as the investigation progresses.

Sincerely,

GROUP5

Incident Response Manager

FinCEN SAR

Organization: FinanceFirst Credit Union

Prepared by: Incident Response Manager

Date: 10th December 2025.

Description of attack

Activity Type: Cyber Event – Ransomware and Extortion

Suspect Name: REvil/Sodinokibi Ransomware Group/or REvil Affiliates

Method of Operation: double extortion

Incident Description and Timeline

Date/Time	Event
Nov 10, 3:42 PM	Initial compromise via phishing email to HR employee
Nov 10, 4:15 PM	Malicious macro executed, TrickBot malware installed
Nov 11-17	Lateral movement, credential harvesting, network reconnaissance
Nov 18	Domain administrator credentials compromised
Nov 19-Dec 1	Data exfiltration (estimated 340 GB transferred to external server)

Date/Time	Event
Dec 1, 4:25 AM	Backup server encrypted
Dec 1, 6:25 AM	Mass encryption of production systems initiated

Identified Indicators of Compromise (IoCs)

- Ransomware File Extension: Files encrypted with the REvil/Sodinokibi variant.
- Ransom Note File: attackers put a file named READ_ME_NOW.txt (attached herein for your reference) across numerous encrypted folders and desktops.
- Malware Artifacts: TrickBot malware deployed.
- Data Exfiltration to a Target IP based in Romania.
- A massive surge in database read volume on the servers hosting the member database and employee records.
- Compromised Credentials.
- Lateral Movement Anomalies.

Ransom note details & payment demand

The attackers provided the following information for payment:

- Ransom Demand: 75 Bitcoin ($2.8M USD), with a 24-hour discounted rate of 50 Bitcoin ($1.9M USD).
- Payment Destination: Bitcoin Wallet: (BITCOIN ADDRESS).
- Communication: TOR Hidden Service Address

Impact on Member Services

- The ransomware attack caused significant disruption to member-facing services. Although core banking systems remained operational. The affected services include:
- Limited Access to Online and Mobile Banking File-Dependent Functions
- Disruption to Branch Operations
- Impact on Loan Origination & Mortgage Processing
- Members are at risk of: Identity theft, Account takeover attempts, Fraudulent loan applications and social engineering attacks leveraging stolen data.

Financial Impact

Operational Recovery: A full network rebuild is necessary, which will significantly extend the service interruption timeline (estimated 21 days), leading to prolonged delays in loan processing

and other critical services. The rebuild will cost the organization $700,000, while the estimated daily revenue loss is as follows:

- Day 1-3: $150,000/day
- Day 4-7: $250,000/day
- Day 8+: $400,000/day

Actions Taken by the Organization

- We have activated the CSIRT team who are currently working to minimize the potential impact of the attack and to promptly restore normal operations.
- We have isolated critical systems to mitigate further data exfiltration and damage.
- We have conducted memory and disk image capture to preserve the relevant evidence.
- We have blocked malicious IPs and domains
- We have conducted a credential reset for domain admin accounts
- Threat hunting for IoCs across the environment
- We have engaged external forensics
- Monitoring Bitcoin wallet activity.

Law enforcement coordination

We are in the process of engaging the FBI to take up the matter, and we intend to fully cooperate with them to catch the perpetrators of the attack.

4. Member notification letter

FinanceFirst Credit Union Letterhead

Date: 03/12/2025

RE: Important Notice About Your Personal Information

Dear Member,

We are writing to inform you of a cybersecurity incident that involved unauthorized access to certain internal FinanceFirst Credit Union systems. Protecting your information is one of our highest priorities, and we want to ensure you have clear and timely information.

What Happened

On 1st December 2025, we detected unusual activity affecting several internal servers. Our investigation, supported by third-party cybersecurity experts, determined that an unauthorized individual gained access to our network and deployed ransomware. During this activity, certain files containing member information were accessed without permission.

What Information Was Involved

The information affected may have included your name, address, date of birth, account number, email address, phone number, and other information maintained as part of your membership.

What We Are Doing

- Immediately isolated affected systems.
- Engaged national cybersecurity forensics experts.
- Notified law enforcement and our federal regulator.
- Implemented additional security controls across our environment.
- Launched a full rebuild of impacted systems to ensure safety and integrity.
- We are offering 24 months of complimentary credit monitoring and identity theft protection services at no cost to you. Instructions for enrollment are included.

What You Can Do

We recommend monitoring your account activity and reporting any suspicious transactions immediately. You may also consider placing a free fraud alert or security freeze with major credit bureaus.

If you have any questions, please call our dedicated support line at (grcgroup5task2.ac.ke), available 7 days a week.

We sincerely regret any concern or inconvenience this incident may cause and remain committed to protecting your personal information.

Sincerely,

FinanceFirst Credit Union

5. **Public statements and media responses**

FinanceFirst Credit Union

Public Statement
December 12, 2025

We are aware of a cybersecurity incident affecting FinanceFirst Credit Union. We take this breach of confidentiality with the utmost seriousness and profoundly regret the distress this news will cause our valued members.

We immediately activated our Incident Response Plan, engaged leading cybersecurity and forensics experts, and notified federal law enforcement and regulators. Out of an abundance of caution, we have isolated affected systems and are working around the clock to restore secure operations.

Our core banking system, mobile banking application, and online banking portal remain operational. Our ATM network remains functional and unaffected. There is no indication that the integrity of your deposits or the security of funds in your accounts has been compromised. We urge our members to remain vigilant. We will be providing comprehensive information and

assistance, including free credit monitoring and identity theft protection services, to all affected individuals.

We will continue to update our website and dedicated information line with the latest details. Our commitment to securing your financial information is unwavering. We are working with federal authorities and cybersecurity experts to resolve the incident.

Media Responses

Are member funds safe?

Yes. Our core banking system and member balances remain intact.

Why the attackers published data despite ongoing negotiations?

The attackers' primary goal is coercion. The publication of data is a standard tactic in double extortion, used to pressure the organization into paying after the initial deadline has passed or when they realize the victim is proceeding with recovery. The "ongoing negotiations" were likely just delaying tactics while the attackers prepared for the final leverage push. Their loyalty is to profit, not promises.

Whether paying now will prevent further publication?

No, payment now is not guaranteed to prevent further publication.

Whether executives should resign to demonstrate accountability?

No, not at this critical juncture. Resignations would destabilize the ongoing response, slow down critical decision-making, and create a leadership vacuum that the organization cannot afford while in the midst of a full-scale rebuild.

6. **Employee communications**

Subject: Important Internal Notice - Cybersecurity Incident Update

Dear Team,

We want to provide a clear update regarding the cybersecurity incident currently affecting our systems. Transparency and coordination are critical at this time, and your cooperation will directly support our recovery efforts.

Earlier today, we identified a ransomware attack impacting several internal systems, including file servers, email, and shared drives. Our core banking platform, online banking, and mobile banking services remain fully operational, and member-facing services continue without interruption.

The incident response team and external cybersecurity experts are actively containing the situation, analyzing affected systems, and working toward restoration.

To ensure the safety of our systems and support containment, please follow these instructions strictly:

- Do NOT use or log into the following systems until further notice: Corporate email (Outlook/Exchange), Shared network drives, Internal file servers, Any workstation that displays unusual messages or inaccessible files.
- Do NOT reboot, power off, or attempt to “fix” any workstation or server.
- Disconnect and report to the IT team immediately if you see unusual behavior.
- Avoid spreading misinformation; Please refrain from discussing the incident with colleagues outside your team or sharing unverified details. This helps maintain accuracy and prevents unnecessary panic.

Mandatory security awareness refresher will be scheduled. If you experience issues or suspect your device may be affected contact the IT Helpdesk immediately. The temporary support email: support-temp@financefirstcus.com .

Please do not provide any information to members of the public; however, direct all inquiries to the Communications Office at: communications@financefirstcu.com .Only designated spokespeople may speak on behalf of the organization during this active incident.

Helpdesk is operating extended hours to support all employees. We appreciate your professionalism, patience, and cooperation during this challenging situation. Together, we will restore full operations safely and securely.

If you have questions, please contact your manager or the IT team.

Thank you,
Incident Response Management Team
FinanceFirst Credit Union.